

Weekly 엔터프라이즈 관리자 가이드 (Admin & Operational Guide)

문서 버전: v0.280.0	대상: 시스템 관리자, Security/DevOps 엔지니어, 데이터 보안 담당자	문서 개요: Weekly 부트스트랩, Keycloak OIDC 자동 SSO, RBAC, 개인 주간보고 자동화·선택 팀원 자료·SMTP, PPTX 템플릿과 감사 로그 운영
-----------------	---	--

1. 시스템 부트스트랩 (Bootstrap Environment Variables)

Weekly 컨테이너 프로세스는 `WEEKLY_POSTGRES_DSN` 하나로 부팅합니다. 관리자 계정이 하나도 없는 데이터베이스, 즉 첫 기동에만 부트스트랩 관리자 2개 변수를 추가로 요구합니다. 업그레이드 후에도 암호화 설정을 복구하기 위해 `WEEKLY_ENCRYPTION_KEY` 를 운영 필수 수준으로 권장합니다.

```
# deploy/.env 파일 설정 예시
WEEKLY_POSTGRES_DSN=postgres://weekly:Secr3tPass@10.10.30.5:5432/weekly?sslmode=disable
# 아래 2개는 첫 기동에만 필요하며, 관리자 계정이 생긴 뒤에는 지웁니다.
WEEKLY_BOOTSTRAP_ADMIN=admin
WEEKLY_BOOTSTRAP_ADMIN_PASSWORD=SuperSecretAdminPassword123!
WEEKLY_ENCRYPTION_KEY=<openssl rand -base64 32 결과>
```

첫 기동 이후 (Bootstrap Secret Removal):

최초 관리자가 만들어지면 `WEEKLY_BOOTSTRAP_ADMIN` 과 `WEEKLY_BOOTSTRAP_ADMIN_PASSWORD` 는 다시 읽히지 않습니다. `.env`, Compose 파일, Kubernetes Secret, CI 변수에서 두 값을 삭제하십시오. 삭제한 뒤에도 컨테이너는 정상 기동합니다. 관리자가 전부 사라진 데이터베이스로 기동하면 두 값을 다시 요구하며 그 사실을 로그에 적고 멈춥니다.

중요 (Volume Backup Notice):

`/var/lib/weekly` 볼륨과 `WEEKLY_ENCRYPTION_KEY` 는 별도로 정기 백업해야 합니다. 기존 볼륨 키만 사용하던 환경은 볼륨을 유지한 상태에서 환경 키를 처음 설정하면 Keycloak/AI/Confluence 비밀번호가 새 키로 자동 재암호화됩니다.

2. Keycloak OIDC SSO 및 RBAC 연동

- 부트스트랩 관리자 계정으로 로그인 → 관리자 설정 → 서비스 설정 → 인증 · Keycloak OIDC 로 이동.
- Valid Redirect URI 등록: `https://weekly.internal/api/v1/auth/oidc/callback`
- Group Claim Mappers 설정 및 관리자 그룹(`ADMIN`) 지정 시 자동 승격 연동.

OIDC가 활성화된 배포에서 Weekly 세션이 없는 브라우저가 앱을 처음 열면 Authorization Code + PKCE 흐름을 `prompt=none` 으로 한 번 시작합니다. Keycloak SSO 세션과 사전 동의가 있으면 로그인 화면 없이 원래 `#/...` 화면으로 돌아오고,

`login_required` · `interaction_required` · `consent_required` · `account_selection_required` 이면 Weekly의 일반 로그인 화면으로 되돌아옵니다. `state`·`nonce`·PKCE와 10분 만료 검증은 대화형 로그인과 동일하며, ID·Access·Refresh Token은 Weekly DB에 보관하지 않습니다.

이 자동 확인은 앱 최초 세션 조회가 401인 경우만 수행합니다. PostgreSQL 장애나 네트워크 실패를 로그아웃으로 오인해 Keycloak으로 보내지 않으며, 작성 중 세션 만료 시에는 전체 탭을 이동하지 않습니다.

Weekly의 명시적 로그아웃은 Keycloak Realm 로그아웃을 호출하지 않고 현재 탭의 자동 확인만 억제합니다. 따라서 다른 사내 서비스의 SSO는 유지되고, 사용자가 SSO 버튼을 직접 누르면 즉시 다시 로그인할 수 있습니다. 이 억제는 브라우저 탭의 `sessionStorage` 에 있으므로 새 탭에는 공유되지 않습니다.

RBAC (Role-Based Access Control) 권한 매트릭스

역할 (Role)	개인 보고서 작성	팀 승인/반려	조직 전체 조회	팀원 자료 선택	PPTX 템플릿 등록	OIDC/시스템 설정	감사 로그
ADMIN	✓	✓	✓	✓ (전체 활성 사용자)	✓	✓	✓
ORG_MANAGER	✓	✓	✓	✓ (소속·하위 조직)	✗	✗	✗

역할 (Role)	개인 보고서 작성	팀 승인/반려	조직 전체 조회	팀원 자료 선택	PPTX 템플릿 등록	OIDC/시스템 설정	감사 로그
TEAM_LEADER	✓	✓	✗ (소속 팀만)	✓ (소속·하위 조직)	✗	✗	✗
USER	✓	✗	✗ (본인 것만)	✗	✗	✗	✗

3. 사내 PPTX 템플릿 등록 및 토큰 검증

관리자 설정 → PPTX 템플릿 메뉴에서 사내 표준 PPTX 파일을 등록합니다. 등록 시 ZIP 구조와 아래 필수 토큰 포함 여부를 자동으로 시스템이 검증합니다.

- `{{WEEK_SCHEDULE}}` : 주간 일정 범위
- `{{THIS_WEEK}}` : 업무별 이번 주 한 일 (필수)
- `{{NEXT_WEEK}}` : 업무별 다음 주 할 일 (필수)
- `{{ISSUES}}` : 주요 이슈 및 지원 요청
- `{{AUTHOR}}` : 작성자
- `{{TEAM}}` : 조직명

기본 4장 참조 형식은 항목 순서를 유지하면서 구분·제목, 예상 줄바꿈과 실적·계획 중 더 긴 열을 비용으로 계산해 슬라이드 높이를 균형화합니다. 같은 구분이 한 장을 넘으면 여러 장으로 나누고 각 장에서 구분 제목을 반복합니다. 관리자 등록 토큰 템플릿은 기존처럼 원본 슬라이드 수와 레이아웃을 변경하지 않습니다.

작성자가 선택한 팀원 자료는 PPTX 생성 직전에 작성자 표기가 붙은 임시 업무 항목으로 평탄화해 본인 항목 뒤에 출력합니다. 기본·관리자 템플릿의 `{{THIS_WEEK}}` · `{{NEXT_WEEK}}` · `{{ISSUES}}` 치환 결과에 같은 순서로 들어가며, 별도 새 슬라이드가 항상 생기는 계약은 아닙니다. 같은 주차의 모든 상태와 미작성 팀원을 표시하지만 임시 항목을 DB에 저장하거나 분석·기간 집계에 더하지 않습니다.

4. API / MCP 키 무중단 회전 (Key Rotation) & 감사 로그 (Audit Log)

- **키 회전:** 관리자는 사내 보안 위협 시 [전체 개인 키 즉시 폐기] 기능을 실행하여 발급된 모든 API/MCP 키를 일괄 무효화할 수 있습니다.
- **감사 로그 (Audit Trail):** 보고서 작성, 승인, 반려, OIDC 설정 변경 및 템플릿 업로드 내역이 DB 감사 로그 테이블에 영구 보존됩니다.

5. AI Gateway 및 Import 정책

서비스 설정의 주차 시작 요일은 월·화·수·목·금·토·일 중 하나를 선택할 수 있습니다. 이 값은 현재 주차 조회, 팀 분석, Confluence 후보, PPTX 날짜와 Import의 단독 날짜 보정에 공통 적용됩니다.

관리자 설정 → **AI** · **Import** 에서 다음 연결값을 관리합니다. 배포 환경에는 연결값 대신 공통 암호화 키만 둡니다.

설정	의미	기본값
AI 사용	사용자 AI 작성·PPTX 분석 허용	꺼짐
Endpoint	OpenAI 호환 Chat Completions 전체 URL	없음
Model	Gateway가 제공하는 모델 식별자	없음
API Key	선택형 Bearer 토큰, 암호화 저장	없음
Timeout	한 번의 AI 호출 제한 시간(초)	90
최대 입력 문자	정규화 입력 상한	50,000
작업당 파일 수	다중 업로드 상한	20
파일당 크기	PPTX 한 개 상한(MB)	25
원본 보존일	확정·건너뒀·실패 원본 보존기간	365

Endpoint와 Model을 먼저 저장하고 **AI 연결 시험** 으로 JSON Schema Structured Output 지원 여부를 확인한 다음 AI 사용을 켭니다. v0.7.0의 모델 계약은 실적·계획·이슈를 원자 문자열 배열로 반환하며, PPTX 분석은 각 항목에 실제 근거 슬라이드 번호와 별도 업무 구분 신뢰도를 요구합니다. 존재하지 않는 슬라이드,

근거 없는 항목 또는 잘못된 구조를 반환하는 모델은 분석 실패로 처리되므로 업그레이드 전에 운영 모델의 Structured Output 호환성을 다시 시험하십시오. API Key 입력란을 비워 저장하면 기존 비밀값이 유지됩니다. 내부 Gateway가 인증을 요구하지 않는 경우 API Key는 비워둘 수 있습니다.

원본 보존기간이 지나면 해당 PPTX 바이너리만 상태 볼륨에서 삭제됩니다. 파일 해시, 추출 텍스트, 구조화 결과, 연결된 보고서와 감사 기록은 PostgreSQL에 남습니다. 원본이 남아 있고 아직 확정되지 않은 **FAILED**, **READY**, **NEEDS_REVIEW** 파일은 파일 ID를 지정해 다시 분석할 수 있습니다. 본문 없는 기존 호출은 종전처럼 실패 파일 전체만 재시도하므로 기존 클라이언트와 호환됩니다. **NEEDS_REVIEW** 는 UI에서 기본 선택하지 않고, 확정 API도 관리자 주차 시작 요일과 항목 구분·제목을 다시 검증합니다.

보안상 AI에는 PPTX 파일 자체가 아니라 서버에서 추출·정규화한 텍스트만 전달됩니다. 추출기는 프레젠테이션 관계의 화면 표시 순서, 원본 슬라이드 번호, 도형 이름, 문단·글머리표 단계, 표 행·열과 빈 셀을 보존합니다. 입력 상한을 넘으면 슬라이드별 공정 예산으로 자르고 일부 내용이 잘린 슬라이드를 **NEEDS_REVIEW** 경고에 기록하므로 운영자는 해당 원본을 대조해야 합니다. 데이터 반출 정책상 외부 AI 호출이 허용되지 않는 환경에서는 사내망 OpenAI 호환 Gateway를 사용하십시오.

6. Confluence 6.9.1 자동화

서비스 설정 → Confluence 6.9.1 자동화 에서 Base URL, **BASIC** 인증, 연동 전용 계정과 암호화 비밀번호를 저장한 뒤 연결 시험을 수행합니다. 대상·제외 Space, 5분 이상의 동기화 주기, Blog 포함 여부, AI/본문 분석, 후보 점수와 업무 키워드를 운영 환경에 맞게 지정합니다. Confluence 연결값 자체는 환경변수로 전달하지 않습니다.

Confluence 자동화 탭에서는 마지막 성공·시도 시각, 조회/변경 Page 수, 생성 후보, 실패 수와 최근 단계별 오류를 확인하고 관리자 강제 증분 Sync를 요청할 수 있습니다. 일반 사용자에게는 Sync 버튼을 제공하지 않습니다.

사용자 매핑 우선순위는 관리자 명시값, Keycloak/Weekly 이메일의 @ 앞부분, Weekly 로그인 아이디입니다. 예를 들어 **hkjang@koreacb.com** 은 Confluence **hkjang** 에 자동 매핑됩니다. 유일하게 판정할 수 없는 미매핑 사용자만 표에서 직접 지정합니다.

Confluence 본문은 PostgreSQL이나 로그에 저장되지 않습니다. 규칙 점수를 통과한 Page의 제한된 본문 미리보기는 제목·문단·목록·표 구조와 입력 앞·뒤 문맥을 보존해 AI 업무 판정과 원자 사실 요약에 일시 사용됩니다. 모델은 각 사실에 하나 이상의 **evidencePageIds** 를 반환하고, 서버는 비어 있거나 실제 입력 Page 집합에 없는 ID를 거부합니다. 의미 검증 실패 시 사유를 포함해 한 번만 교정 호출하며 재실패하면

AI_SUMMARY 진단 후 결정적 제목 기반 후보로 대체합니다. 검색 메타데이터와 본문 조회 사이에 Page Version이 달라지면 **BODY_VERSION_CHANGED** 단계 진단을 남기고 해당 버전을 후보에 연결하지 않습니다.

이는 동기화 중 수정된 두 버전의 내용을 섞지 않기 위한 재시도 가능한 상태입니다. 외부 AI 데이터 반출이 허용되지 않으면 사내 AI Gateway를 사용하거나 [후보 문서 본문 분석](#) 을 끄십시오. 전체 운영 규격과 장애 코드는 [Confluence 연동 문서](CONFLUENCE.md)를 참고하십시오.

7. 개인 주간보고 자동화와 권고 메일 운영

사용자는 [개인 설정 → 주간보고 자동화](#) 에서 지난주 전체 자동 복제를 켤 수 있습니다. 팀장·조직장·관리자에게는 자동 권고 메일과 발송 요일 선택, 별도 [팀원 작성 권고 메일](#) 카드의 [지금 권고 메일 보내기](#) 가 추가로 보입니다. 자동 설정 저장은 Worker를 깨우며, 서비스 기동 시 한 번 실행한 뒤 매분 현재 주차를 확인합니다. 수동 버튼은 자동 설정과 독립적으로 현재 주차 대상을 즉시 큐에 넣고 메일 Worker를 깨웁니다.

자동화	실행 기준	대상과 중복 방지	외부 의존성
지난주 전체 자동 복제	새 보고 주차, 서비스 시간대와 <code>workflow.week_start</code> 기준	사용자별 주차당 한 번. 이번 주와 날짜가 겹치는 보고서가 있으면 건너뛴다	없음
팀원 작성 권고	선택한 요일 오전 9시 이후 자동, 또는 권고자의 즉시 요청	받는 사람별 주차당 한 번. 보고서가 없거나 <code>DRAFT</code> 인 활성 사용자만	사용 가능한 SMTP 설정

자동 복제는 정확히 한 주 전 보고서에 업무 항목이 있을 때 요약과 구분·실적·계획·이슈·상위 조직 요청·진척도 및 이어지는 업무 식별자를 새 `DRAFT` 로 복제합니다. 댓글·검토 이력·첨부·외부 출처는 옮기지 않습니다. `user_weekly_preferences.auto_clone_processed_week` 을 먼저 잠그고 처리하므로 여러 프로세스가 동시에 확인해도 같은 초안을 둘 만들지 않으며, 사용자가 자동 초안을 지운 뒤 매분 되살아나지도 않습니다.

권고 메일의 범위는 서버가 발송 직전 다시 계산합니다.

- `TEAM_LEADER` 와 `ORG_MANAGER` : 본인이 속한 조직과 전체 하위 조직. 소속 조직이 없으면 발송하지 않습니다.
- `ADMIN` : 조직과 관계없이 전체 활성 사용자.
- 공통: 권고자 본인은 제외하고, 사용자의 개인 메일 주소를 우선 사용하며 없으면 계정 이메일로 대체합니다. 유효한 주소가 없으면 로그에 건수만 남기고 건너뛴다.
- 여러 권고자의 조직 범위가 겹쳐도 `recipient_user_id + week_start` 유일 제약으로 한 통만 만듭니다. 큐를 집은 뒤에도 제출 여부, 현재 주차와 권고자의 활성 상태·역할·조직 범위를 다시 확인해 오래된 권고를 폐기하며, `AUTO` 행은 자동 발송 설정도 다시 확인합니다.

`POST /api/v1/me/team-reminders` 는 `TEAM_LEADER` , `ORG_MANAGER` , `ADMIN` 만 호출할 수 있습니다. 서버는 요청 트랜잭션 안에서 현재 역할·조직 범위와 이번 주의 미제출 대상을 다시 읽으며, 자동 발송 사용 여부와 저장한 요일은 보지 않습니다. 응답의 `eligible` , `queued` , `alreadyQueued` , `skippedNoAddress` 로 요청 결과를 구분합니다. 같은 주의 `QUEUED` · `SENT` 행은 중복으로 집계하고, 재시도까지 끝나 `FAILED` 가 된 행은 현재 주소와 권한으로 `MANUAL` 대기열에 다시 엽니다.

권고 메일은 기존 보고서 제출 메일과 같은 SMTP 연결, 전체 제한시간, 최대 시도 횟수와 지수형 재시도를 사용합니다. 자동 확인 시 SMTP가 준비되지 않았으면 과거 주차 backlog를 만들지 않고 현재 주 안에 설정이 정상화된 다음 분에 따라잡습니다. 수동 API는 사용할 수 없는 SMTP에서 `409 MAIL_RELAY_NOT_READY` 를 반환하고 큐를 만들지 않습니다. `mail.enabled` , 호스트·포트·보내는 주소와 보안을 저장하고 관리자 시험 메일을 통과시킨 뒤 팀장에게 기능을 안내하십시오. 서비스 시간대가 실제 조직 시간대와 다르면 오전 9시도 그만큼 어긋나므로 `service.timezone` 을 함께 확인해야 합니다.

새 데이터는 `user_weekly_preferences` 와 `team_reminder_deliveries` 두 테이블에 저장됩니다. 후자의 `origin` 은 `AUTO` 와 `MANUAL` 을 구분하며, 자동 설정 변경은 자동으로 만든 대기 행만 취소합니다. 설정 저장은 `weekly.preference` , 자동 복제는 `report.auto_clone` , 자동 권고 큐 생성은 `mail.team_reminders_queued` , 수동 요청과 처리 건수는 `mail.team_reminders_manual` 감사 이벤트로 남습니다. 주소 누락, 재시도와 최종 실패는 서버 로그에 기록됩니다. 현재 관리자 메일 현황 카드와 사용자 발송 이력은 제출 메일만 집계하며 팀 권고 메일의 개별 결과 화면은 제공하지 않으므로, 권고 장애는 서버 로그와 큐 테이블을 함께 확인하십시오.

8. 선택 팀원 주간보고 자료 운영

`GET/PUT /api/v1/me/report-inclusions` 는 로그인 사용자의 포함 대상 설정을 조회·저장하며 응답의 `maxMembers` 가 현재 선택 상한을 알립니다. `PUT` 의 `memberIds` 는 최대 500개이며 중복 ID는 서버가 정규화합니다. 빈 배열은 현재 역할과 관계없이 본인의 선택을 모두 해제합니다. 양수 ID가 아니거나 상한을 넘으면 `400 INVALID_REPORT_INCLUSIONS` , 본인·비활성·존재하지 않음·현재 조직 범위 밖 대상은 존재 여부를 구분하지 않고 `403 REPORT_INCLUSION_MEMBER_FORBIDDEN` 으로 거부합니다. 일반 사용자가 비어 있지 않은 대상을 저장하면 `403 REPORT_INCLUSION_ROLE_REQUIRED` 입니다.

권한과 조회 범위는 다음과 같이 매번 다시 계산합니다.

- `TEAM_LEADER` , `ORG_MANAGER` : 본인이 속한 조직과 전체 하위 조직의 활성 사용자. 소속 조직이 없으면 대상이 없습니다.
- `ADMIN` : 조직과 관계없이 전체 활성 사용자.

- 공통: 본인은 제외합니다. 강등·조직 이동·비활성화 때 `user_report_inclusions` 행을 자동 삭제하지 않고 조회에서 가립니다. 다시 같은 권한 범위에 들어오면 기존 선택이 다시 유효해집니다.

보고 상세 응답의 `includedMaterials` 는 보고서 소유자의 **현재 선택**과 그 보고서의 정확한 `weekStart` 를 결합한 읽기 모델입니다. 본인의 이번 주 보고서가 아직 없을 때는 `GET /api/v1/reports/current/included-materials` 로 같은 자료를 조회합니다. 선택 팀원의 보고 상태는 필터링하지 않고 원래 상태를 표시하며, 보고서가 없는 팀원도 빈 업무 목록과 미작성 표시로 응답합니다.

다른 사용자가 보고 상세를 조회할 때는 바깥 보고서 조회 권한에 더해 조회자 본인의 현재 조직 범위와 포함 대상의 교집합만 반환합니다. 관리자 보고서에 전사 선택이 있더라도 그 보고서를 보는 팀장에게 자기 조직 밖 팀원 자료가 새로 노출되지는 않습니다.

화면·발표·제출 메일은 본인 내용 뒤에 별도 **선택 팀원 포함 자료** 구획을 만들고, PPTX는 출력 직전에 같은 자료를 임시 항목으로 평탄화해 본인 항목 뒤에 이어 붙입니다. PPTX의 임시 항목 분류는 **선택 팀원 · 이름 (아이디) · 원래 분류** 로 작성자와 출처 분류를 보존합니다. 포함은 한 단계만 허용하므로 선택 팀원의 `includedMaterials` 를 재귀적으로 따라가지 않습니다. 이미 보낸 메일과 내려받은 파일은 바뀌지 않지만, 이후 과거 보고서를 조회하거나 새 출력을 만들면 현재 선택·현재 권한으로 해당 과거 주차 자료를 다시 계산합니다.

마이그레이션 `027_report_inclusions.sql` 은 대상 관계만 `user_report_inclusions` 에 저장합니다. 팀원 `weekly_reports · report_items` 를 소유자 보고서로 복제하지 않으며 소유자 보고서의 상태·버전·검토 이력을 바꾸지 않습니다. 기간 보고, 팀 종합, 제출률, 업무 추적과 관리자 분석은 기존 원본만 집계하므로 포함 자료를 두 번 세지 않습니다. 설정 변경은 `weekly.report_inclusions` 감사 이벤트로 기록됩니다.